



Unidad Didáctica

**Marcos metodológicos para el
desarrollo de la auditoria, Unidad II**

Contenido

Índice de Contenido	2
Introducción	3
Desarrollo de Contenidos	4
Antecedentes y Conceptos generales.....	4
Metodologías de Evaluación de los recursos de TI	10
Proceso Metodológico de Auditoria de TI	20
Bibliografía y Webgrafía	21
Glosario	21

Introducción

La auditoría en tecnologías de la información (TI) ha evolucionado hasta convertirse en un pilar fundamental para la gobernanza corporativa, la gestión de riesgos y el aseguramiento del cumplimiento normativo en las organizaciones modernas. En este contexto, la presente Unidad II, titulada "Marcos metodológicos para el desarrollo de la auditoría", se centra en el estudio y aplicación de las estructuras conceptuales y prácticas que guían el quehacer del auditor de TI.

Para abordar esta temática de manera integral, el contenido se ha estructurado en tres ejes fundamentales. En primer lugar, se explorarán los antecedentes y conceptos generales, estableciendo la base histórica y terminológica necesaria para comprender la evolución de las metodologías actuales. Posteriormente, se analizarán las principales metodologías de evaluación de los recursos de TI, profundizando en los estándares, marcos de referencia y mejores prácticas reconocidas a nivel internacional que permiten diagnosticar y valorar el entorno tecnológico. Finalmente, se describirá el proceso metodológico de la auditoría de TI, detallando las fases, técnicas y herramientas que conforman el ciclo de vida de una auditoría, desde su planificación hasta la emisión del informe final.

El dominio de estos marcos metodológicos no solo dotará al estudiante de las competencias técnicas para ejecutar auditorías eficaces, sino que también le proporcionará una visión estratégica para alinear los hallazgos tecnológicos con los objetivos del negocio.

Antecedentes y Conceptos generales

En la Unidad I, estudiamos la evolución de la auditoría desde sus orígenes hasta la era digital, y cómo surgió la necesidad de una especialización en TI. Ahora, nos adentraremos en un aspecto crucial de esa evolución: la necesidad de metodologizar la práctica. Así como un médico no puede diagnosticar basándose únicamente en su intuición, sino que sigue un protocolo clínico, un auditor de TI no puede evaluar un sistema complejo sin un método estructurado. En este tema, exploraremos los antecedentes que llevaron a la creación de estos métodos y definiremos el lenguaje básico que utilizaremos para hablar de ellos.

Antecedentes: La necesidad de un enfoque estructurado

Los primeros auditores de TI, como vimos, auditaban "alrededor" del ordenador. Pero a medida que los sistemas se volvieron más complejos, interconectados y críticos para el negocio, este enfoque artesanal se volvió insuficiente y peligroso. Surgieron varios factores que impulsaron la necesidad de metodologías formales:

- Complejidad creciente de los sistemas: Los entornos de mainframe dieron paso a redes cliente-servidor, luego a internet y ahora a la nube. Esta complejidad hacía imposible auditar sin un plan que guiara la revisión.
- Aparición de estándares y marcos de control: Organizaciones como ISACA, el IIA y organismos gubernamentales comenzaron a publicar guías y estándares (como los primeros COBIT y las guías para auditorías gubernamentales). Esto creó una base de conocimiento común que los auditores podían y debían utilizar.
- Mayor escrutinio regulatorio: Leyes como SOX en EE.UU. (y posteriormente normativas locales como las de la SIBOIF) no solo exigían controles, sino que

implícitamente requerían que los auditores tuvieran un método para evaluarlos de manera consistente y defendible.

- Necesidad de calidad y consistencia: Las firmas de auditoría y los departamentos de auditoría interna necesitaban asegurar que todas sus auditorías se realizaran con un mismo nivel de calidad, independientemente del auditor asignado. Una metodología estandarizada garantiza esa consistencia.
- Profesionalización de la disciplina: La creación de certificaciones como CISA (Certified Information Systems Auditor) por parte de ISACA en 1978 consolidó un cuerpo de conocimientos y prácticas que todo auditor de TI debía dominar, sentando las bases para metodologías de trabajo estandarizadas.

Conceptos Fundamentales: El Lenguaje del Método

Para adentrarnos en las metodologías, es esencial distinguir entre los conceptos de metodología, enfoque, técnica y procedimiento. A menudo se usan como sinónimos, pero tienen significados específicos y jerárquicos.

- Metodología: Es el marco general que guía todo el proceso de auditoría. Es un sistema de métodos, principios y reglas que estructura la forma de pensar y actuar del auditor desde el inicio hasta el final. Una metodología responde al "cómo" de manera integral. Por ejemplo, la metodología de auditoría de una firma como Deloitte o KPMG incluye sus propias herramientas, guías y secuencias de trabajo basadas en estándares internacionales.
- Enfoque: Es la perspectiva o estrategia que se adopta dentro de una metodología para abordar una auditoría específica. Responde a la pregunta "¿por dónde vamos a atacar el problema?". Depende del objetivo y el riesgo. Por ejemplo, se puede tener un enfoque de auditoría basado en riesgos (centrar los esfuerzos en las áreas de mayor riesgo) o un enfoque de auditoría de controles (centrarse en verificar la existencia y efectividad de los

controles). También puede ser un enfoque sistémico (revisar todo el sistema) o selectivo (revisar solo partes críticas).

- **Técnica:** Es el método específico que se utiliza para obtener evidencia o realizar una revisión puntual. Son las herramientas intelectuales o prácticas del auditor. Ejemplos de técnicas son: la entrevista, la revisión documental, el análisis de datos, la observación, el cuestionario, el muestreo, el análisis de flujo, la prueba de recorrido (walkthrough).
- **Procedimiento:** Es la secuencia detallada de pasos que se siguen para aplicar una técnica o para completar una parte del trabajo. Es el "cómo" a nivel más granular. Por ejemplo, el procedimiento para realizar un análisis de logs de acceso implicaría: 1) Solicitar los logs al administrador, 2) Verificar su integridad, 3) Importarlos a una herramienta de análisis (como Excel o un SIEM), 4) Filtrar por eventos fallidos, 5) Identificar IPs sospechosas, etc.

Ejemplo:

Imaginemos que el equipo de auditoría interna de BANPRO va a auditar el sistema de banca en línea. Su metodología (basada en estándares ISACA y normas de la SIBOIF) les dice que deben planificar, ejecutar, reportar y dar seguimiento. Dentro de esa metodología, adoptan un enfoque basado en riesgos, decidiendo enfocarse en la seguridad lógica (autenticación de usuarios) porque es el área de mayor riesgo. Para evaluar la autenticación, utilizan la técnica de la entrevista con el administrador del sistema y la técnica del análisis de datos. El procedimiento para el análisis de datos sería: solicitar al área de TI un listado de todos los intentos de acceso fallidos del último mes y revisar si hubo un patrón de ataques de fuerza bruta desde una misma IP.

La Importancia de Seguir una Metodología

Seguir una metodología no es un mero formalismo. Aporta beneficios tangibles:

- Rigor y consistencia: Asegura que la auditoría cubra todos los aspectos importantes de manera sistemática.
- Eficiencia: Guía al auditor, evitando que se pierda o que invierta tiempo en áreas poco relevantes.
- Objetividad: Proporciona un marco que reduce la subjetividad y los sesgos personales.
- Defendibilidad: Los hallazgos y conclusiones, al basarse en un método reconocido, son más fáciles de defender ante la gerencia, el comité de auditoría o incluso en un tribunal.
- Calidad: Facilita la supervisión y revisión del trabajo, asegurando que se cumplen los estándares de calidad de la firma o departamento.

Autoevaluación

Responde las siguientes preguntas para verificar tu comprensión sobre los antecedentes y conceptos generales de las metodologías de auditoría de TI.

Pregunta 1:

¿Cuál de los siguientes NO fue un factor que impulsó la necesidad de metodologías formales en la auditoría de TI?

- a) La creciente complejidad de los sistemas informáticos.
- b) La aparición de estándares y marcos de control como los de ISACA.
- c) La disminución de la dependencia de las organizaciones de la tecnología.
- d) Un mayor escrutinio regulatorio y legal.

Pregunta 2:

El concepto que se refiere al "marco general que guía todo el proceso de auditoría, desde el inicio hasta el fin" es:

- a) Técnica
- b) Enfoque
- c) Procedimiento
- d) Metodología

Pregunta 3:

Si un auditor decide centrar sus pruebas en los sistemas de facturación porque representan el mayor riesgo de pérdida financiera para la empresa, está definiendo:

- a) La metodología de la auditoría.
- b) El enfoque de la auditoría.
- c) Un procedimiento de auditoría.
- d) Una técnica de auditoría.

Pregunta 4:

Realizar una entrevista al jefe de seguridad de la información para entender el proceso de gestión de accesos es un ejemplo de:

- a) Una metodología.
- b) Un enfoque.
- c) Una técnica.
- d) Un procedimiento.

Pregunta 5:

Relaciona los siguientes ejemplos con el concepto correcto (Técnica, Procedimiento, Enfoque, Metodología):

El manual de auditoría de la Contraloría General de la República que dicta los pasos a seguir en cualquier auditoría gubernamental. _____

Decidir auditar los sistemas de nómina y recursos humanos por ser áreas sensibles.

Utilizar un software de análisis de datos (CAATT) para detectar pagos duplicados en el sistema de proveedores. _____

Los pasos específicos para configurar el software de análisis de datos y ejecutar la consulta de pagos duplicados. _____

Metodologías de Evaluación de los recursos de TI

Una vez comprendida la necesidad de un enfoque estructurado y el lenguaje asociado, nos enfrentamos a la pregunta: ¿qué metodologías específicas existen para evaluar los recursos de TI? La respuesta no es única. Existe una variedad de marcos, estándares y guías que, según el objetivo de la evaluación, pueden utilizarse de manera independiente o combinada.

En este tema, exploraremos las principales metodologías y marcos de referencia que un auditor de TI debe conocer, no solo como criterios de auditoría (como vimos en la Unidad I), sino como verdaderas guías para estructurar su trabajo de evaluación.

Clasificación de las Metodologías de Evaluación

Podemos clasificar las metodologías según su propósito principal:

1. Metodologías de Gobierno y Gestión: Se enfocan en cómo se organiza, planifica, dirige y controla la función de TI a nivel estratégico y táctico.
2. Metodologías de Evaluación de Controles y Seguridad: Se centran en verificar la existencia y efectividad de los controles específicos para proteger la información y los sistemas.
3. Metodologías de Gestión de Riesgos: Se enfocan en identificar, analizar y evaluar los riesgos tecnológicos.
4. Metodologías de Gestión de Servicios: Se centran en la calidad de los servicios de TI que se prestan al negocio.

Principales Metodologías y Marcos de Referencia

A continuación, analizaremos las más relevantes, profundizando en cómo el auditor de TI las utiliza en su labor.

A. COBIT (Control Objectives for Information and Related Technologies)

Como vimos en la Unidad I, COBIT es el marco de referencia por excelencia para el auditor de TI. Pero no es solo un conjunto de criterios; es una metodología de gobierno y gestión que proporciona un modelo de procesos y objetivos de control. La versión más reciente, COBIT 2019, introduce el concepto de "factores de diseño", que permiten personalizar el sistema de gobierno a las necesidades específicas de la organización.

Uso por el auditor de TI: COBIT sirve al auditor de múltiples maneras:

- Para entender el negocio: Ayuda a mapear las metas del negocio con las metas de TI, permitiendo al auditor enfocarse en lo que realmente importa para la organización.
- Como guía para la evaluación de procesos: El modelo de procesos de COBIT (EDM, APO, BAI, DSS, MEA) proporciona un checklist de lo que se espera de un proceso de TI bien gestionado. Por ejemplo, para auditar el proceso de "Gestión de Cambios" (BAI06 en COBIT 5), el auditor puede utilizar los objetivos de control de COBIT para asegurarse de que está revisando todos los aspectos clave: solicitud de cambio, aprobación, evaluación de impacto, pruebas, implementación y documentación.
- Para evaluar la madurez de la gestión: COBIT incluye modelos de capacidad de procesos que permiten al auditor calificar qué tan maduro es un proceso (desde "incompleto" hasta "optimizado").

Ejemplo:

Un auditor de la Superintendencia de Bancos (SIBOIF) que supervisa un banco como LAFISE puede utilizar COBIT 2019 para evaluar el proceso de "Gestión de la Seguridad" (DSS05). El marco le dirá que debe revisar, entre otras cosas, la gestión de identidades y accesos, la gestión de vulnerabilidades y la protección ante malware. Esto le proporciona una estructura sólida para su revisión.

B. ITIL (Information Technology Infrastructure Library)

ITIL es el marco de referencia para la gestión de servicios de TI (ITSM). Su enfoque está en alinear los servicios de TI con las necesidades del negocio y en gestionar el ciclo de vida de los servicios (estrategia, diseño, transición, operación y mejora continua). La versión actual, ITIL 4, se centra en la creación de valor a través de un Sistema de Valor del Servicio (SVS) y un modelo de 34 prácticas.

Uso por el auditor de TI: ITIL es la herramienta perfecta para auditar la calidad del servicio y la eficiencia operativa de TI.

- Auditoría de la Gestión de Incidentes: El auditor puede comparar el proceso de atención de incidencias de la organización con las prácticas de ITIL (registro, categorización, priorización, escalamiento, resolución y cierre) para identificar cuellos de botella o desviaciones.
- Auditoría de la Gestión de Niveles de Servicio (SLA): ITIL proporciona las directrices para evaluar si los acuerdos de nivel de servicio (SLA) con los usuarios están bien definidos, si se monitorean y si se cumplen.

Ejemplo:

El departamento de TI de la Alcaldía de Managua tiene un acuerdo de nivel de servicio con las diferentes direcciones (como Catastro o Recaudación) que promete resolver incidencias críticas en un máximo de 4 horas. Un auditor interno con conocimientos de ITIL puede revisar los tickets de incidencias del último trimestre y verificar cuántas se resolvieron dentro del plazo, analizando las causas de los retrasos (falta de personal, problemas de escalamiento, etc.) y recomendando mejoras en el proceso.

C. ISO/IEC 27001:2022 (Sistema de Gestión de Seguridad de la Información)

Como se estudió en la Unidad I, esta es la norma internacional para la gestión de la seguridad de la información. Establece los requisitos para implementar, mantener y mejorar un SGSI. Su Anexo A contiene 93 controles agrupados en 4 categorías (Organizacionales, de Personas, Físicos y Tecnológicos).

Uso por el auditor de TI: ISO 27001 es a la vez un criterio y una metodología.

- Como criterio: Es la base para las auditorías de certificación. Un auditor externo evalúa si la organización cumple con todos los requisitos de la norma.
- Como metodología de evaluación de controles: Incluso si la organización no busca la certificación, el auditor de TI puede utilizar el Anexo A de ISO 27001 como un checklist completo y reconocido internacionalmente para evaluar la madurez de sus controles de seguridad. Puede revisar, por ejemplo, los controles relacionados con la seguridad física (A.7), la seguridad de las operaciones (A.8) o la gestión de incidentes (A.5.24).

Ejemplo:

Una empresa de zonas francas que maneja datos confidenciales de clientes extranjeros (por ejemplo, una empresa de servicios BPO) quiere demostrar a sus clientes que protege adecuadamente la información. Contrata a un auditor para que realice una evaluación de brecha (gap analysis) contra la ISO 27001. El auditor utilizará la norma como metodología para identificar todas las áreas donde la empresa cumple y donde necesita mejorar para poder certificarse en el futuro.

D. COSO (Committee of Sponsoring Organizations)

COSO, como vimos, es el marco para el control interno. Si bien no es específico de TI, es fundamental porque el control interno en TI es una parte del control interno de la organización. COSO proporciona la visión holística.

Uso por el auditor de TI: El auditor de TI utiliza COSO para asegurar que su evaluación de los controles de TI se alinea con la estructura de control general de la organización. Por ejemplo, al evaluar el Ambiente de Control en TI, revisará si la dirección de TI promueve una cultura ética y de cumplimiento. Al evaluar la Evaluación de Riesgos, verificará si TI tiene un proceso formal para identificar sus riesgos tecnológicos. Al revisar las Actividades de Control, se enfocará en los controles generales y de aplicación. La Información y Comunicación la usará para ver si los reportes de TI son confiables. Y la Supervisión la aplicará para ver cómo se monitorean los controles de TI.

Ejemplo:

La auditoría interna del Ministerio de Educación (MINED) está realizando una evaluación general del control interno en el ministerio. El equipo de auditores financieros y el auditor de TI trabajan juntos usando el marco COSO. El auditor de TI aporta su visión sobre cómo los sistemas informáticos (como el de matrícula

escolar o el de nómina de maestros) impactan en los cinco componentes de COSO, asegurando que la evaluación sea integral.

E. Metodologías de Evaluación de Riesgos (MAGERIT, NIST SP 800-30)

Estas metodologías se centran en el proceso de análisis y gestión de riesgos. Son fundamentales para la auditoría, ya que el enfoque actual de la auditoría es basado en riesgos.

1. MAGERIT (Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información): Es una metodología de origen español, muy utilizada en la administración pública de España y con influencia en América Latina. Proporciona un método estructurado para analizar los riesgos (activos, amenazas, vulnerabilidades, impactos) y gestionarlos.
2. NIST SP 800-30 (Guide for Conducting Risk Assessments): Es la guía del NIST (Instituto Nacional de Estándares y Tecnología de EE.UU.) para realizar evaluaciones de riesgos. Es muy detallada y utilizada globalmente.

Uso por el auditor de TI: El auditor utiliza estas metodologías para:

- Planificar la auditoría: Para identificar las áreas, sistemas o procesos de mayor riesgo y enfocar allí sus recursos (enfoque basado en riesgos).
- Evaluar el proceso de riesgos de la organización: Para revisar si la organización cuenta con un proceso formal de gestión de riesgos de TI y si lo ejecuta adecuadamente. El auditor comparará el proceso de la empresa con lo que dicta la metodología (MAGERIT o NIST).

Ejemplo en Nicaragua:

Antes de iniciar la auditoría anual en TIGO Nicaragua, el equipo de auditores de TI realiza un ejercicio de análisis de riesgos utilizando como guía la metodología NIST SP 800-30. Identifican que el riesgo de un ataque de ransomware a los sistemas de atención al cliente es muy alto. Como resultado, deciden enfocar una parte importante de su tiempo y recursos en auditar los controles de backup, los planes de continuidad y la seguridad perimetral de esos sistemas.

Integración de Metodologías: El "Paraguas" de COBIT

En la práctica, las metodologías no se utilizan de forma aislada. Un auditor experimentado sabe combinarlas para obtener una visión completa. COBIT, en sus versiones más recientes, actúa como un "paraguas" integrador que permite alinear y relacionar los otros marcos.

MARCO/METODOLOGÍA	PROPÓSITO PRINCIPAL	USO PRINCIPAL POR EL AUDITOR DE TI
COBIT	Gobierno y Gestión de TI	Marco integrador para evaluar la gestión global de TI. Proporciona el "qué" auditar.
ITIL	Gestión de Servicios de TI	Evaluar la eficiencia y calidad de las operaciones y servicios de TI.
ISO 27001	Gestión de Seguridad de la Información	Evaluar la madurez y efectividad de los controles de seguridad.
COSO	Control Interno	Alinear la evaluación de controles de TI con el control interno general de la organización.
MAGERIT / NIST	Gestión de Riesgos de TI	Evaluar el proceso de gestión de riesgos de la organización y planificar la auditoría.

Autoevaluación

Responde las siguientes preguntas para verificar tu comprensión sobre las metodologías de evaluación de recursos de TI.

Pregunta 1:

Un auditor de TI necesita evaluar la eficiencia del proceso de atención de incidencias y solicitudes de los usuarios del departamento de TI. ¿Qué marco de referencia sería el más adecuado para obtener criterios de auditoría sobre este proceso?

- a) COBIT
- b) ITIL
- c) ISO 27001
- d) MAGERIT

Pregunta 2:

Si el objetivo es evaluar la madurez de los controles de seguridad de una organización utilizando un checklist internacionalmente reconocido, el auditor podría basarse en:

- a) El modelo de procesos de COBIT.
- b) Las prácticas de ITIL.
- c) El Anexo A de la norma ISO 27001.
- d) La guía NIST SP 800-30.

Pregunta 3:

Un auditor está planificando su trabajo y necesita identificar las áreas de mayor riesgo para enfocar sus esfuerzos. ¿Qué tipo de metodología le será de mayor utilidad en esta fase?

- a) Metodología de gobierno (COBIT).
- b) Metodología de gestión de servicios (ITIL).

- c) Metodología de evaluación de riesgos (MAGERIT, NIST).
- d) Metodología de control interno (COSO).

Pregunta 4:

¿Cuál de los siguientes marcos de referencia es conocido por actuar como un "paraguas integrador" que permite alinear otros marcos como ITIL e ISO 27001?

- a) COSO
- b) COBIT
- c) MAGERIT
- d) PMBOK (Project Management Body of Knowledge)

Pregunta 5 (Caso práctico):

La Contraloría General de la República (CGR) de Nicaragua está desarrollando una nueva guía metodológica para que sus auditores realicen auditorías de sistemas de información en las alcaldías. Quieren que esta guía se base en un marco de gobierno de TI ampliamente aceptado, que les ayude a evaluar si las TI de las alcaldías están alineadas con los objetivos municipales y si sus procesos están bien gestionados. ¿Qué marco deberían tomar como base principal?

- a) ITIL
- b) ISO 27001
- c) COBIT
- d) PMBOK

Proceso Metodológico de Auditoría de TI

Proceso Metodológico de Auditoría de TI

Una vez que conocemos las diferentes metodologías y marcos que nos guían, es hora de ensamblar todas las piezas en un proceso concreto. La auditoría de TI, como cualquier disciplina profesional, sigue un ciclo de vida estructurado. Este proceso metodológico asegura que la auditoría sea sistemática, completa y que sus resultados sean confiables y útiles para la organización.

El proceso de auditoría de TI se divide generalmente en cinco grandes fases. Aunque el nombre o el número de fases puede variar ligeramente según la metodología específica de cada firma, el espíritu y las actividades principales son comunes.

Las cinco fases del proceso de auditoría de TI son:

flowchart TD

A[1. Planificación] --> B[2. Trabajo de Campo
(Ejecución)]

B --> C[3. Desarrollo de Hallazgos
y Conclusiones]

C --> D[4. Comunicación de Resultados
(Informe)]

D --> E[5. Seguimiento]

E --> A

A continuación, exploraremos en detalle cada una de estas fases.

Fase 1: Planificación de la Auditoría

La planificación es la fase más importante. Una mala planificación conduce a una auditoría ineficiente, que puede pasar por alto riesgos críticos o malgastar recursos en áreas irrelevantes. En esta fase, el auditor "diseña" la auditoría.

Actividades Clave:

1. **Conocimiento del Negocio y del Entorno a Auditar:** El auditor debe comprender la misión, visión, objetivos estratégicos y procesos de negocio de la organización o área auditada. También debe identificar el marco legal y normativo aplicable (leyes nicaragüenses como la 1042, normas SIBOIF, NAGUN, etc.).
2. **Evaluación Preliminar de Riesgos:** Se realiza una identificación inicial de los riesgos que podrían afectar al área o sistema auditado. Se responde a preguntas como: ¿Qué puede salir mal? ¿Qué activos son más críticos? ¿Qué amenazas existen? Esto ayuda a definir el enfoque de la auditoría. Herramientas como MAGERIT o NIST pueden ser útiles aquí.
3. **Definición del Alcance y los Objetivos:**
 - **Alcance:** Define los límites de la auditoría. ¿Qué sistemas, procesos, ubicaciones físicas o períodos de tiempo se incluirán? Por ejemplo: "La auditoría abarcará el módulo de facturación del sistema SAP, los servidores de base de datos Oracle que lo soportan y las políticas de gestión de cambios aplicables durante el año 2024 en la oficina central de Managua".
 - **Objetivos:** Definen qué se espera lograr con la auditoría. Por ejemplo: "Evaluar si los controles de acceso al módulo de facturación garantizan la confidencialidad de los precios y descuentos de los clientes".

4. Identificación de los Criterios de Auditoría: Se definen las normas, estándares o políticas contra las cuales se comparará la evidencia. Por ejemplo: Políticas internas de seguridad de la empresa, normas de la SIBOIF, controles del Anexo A de ISO 27001, etc.
5. Elaboración del Programa de Trabajo: Es el "plan de vuelo" detallado de la auditoría. El programa de trabajo lista, en orden, los procedimientos específicos que se llevarán a cabo (entrevistas, revisiones documentales, pruebas de control, análisis de datos, etc.), asignando un responsable y un tiempo estimado para cada uno. Este programa es flexible y puede ajustarse durante la ejecución.
6. Asignación de Recursos: Se determina el equipo de auditoría (número de personas, habilidades necesarias) y el presupuesto de tiempo y, si aplica, económico.
7. Comunicación de Inicio (Carta de Encargo): Se envía una comunicación formal al auditado informando sobre la auditoría, sus objetivos, alcance, fechas y el equipo de auditores.

Ejemplo:

El auditor interno de LA COLMENA va a planificar la auditoría al sistema de gestión de inventarios. En la fase de planificación, se reúne con el gerente de logística para entender el negocio, identifica que el riesgo principal es el desabastecimiento o el exceso de inventario (que inmoviliza capital), define el alcance (sucursales de Managua y el centro de distribución), los objetivos (verificar la exactitud de los registros de inventario) y los criterios (políticas internas de conteo cíclico y norma internacional de información financiera para inventarios). Luego, elabora un programa de trabajo que incluye procedimientos como: entrevistar a los bodegueros, revisar los últimos conteos cíclicos y analizar los movimientos de inventario en el sistema ERP.

Fase 2: Trabajo de Campo (Ejecución)

Es la fase donde se ejecuta el programa de trabajo y se recolecta la evidencia. El auditor se convierte en un "investigador" que aplica diversas técnicas para obtener la información que sustentará sus conclusiones.

Actividades Clave:

1. **Aplicación de Técnicas de Auditoría:** Se llevan a cabo los procedimientos definidos en el programa de trabajo.
2. **Entrevistas:** Con el personal clave (administradores de sistemas, usuarios, jefes de área) para comprender los procesos y controles.
3. **Revisión Documental:** Análisis de políticas, procedimientos, manuales, actas de comités, reportes, contratos, etc.
4. **Observación:** Presenciar la ejecución de una actividad para verificar si se hace según lo establecido (ej. observar cómo un operador realiza un backup).
5. **Cuestionarios:** Envío de listas de preguntas estandarizadas para recolectar información de manera eficiente.
6. **Pruebas de Recorrido (Walkthroughs):** El auditor selecciona una transacción y sigue su rastro a través del sistema, desde el inicio hasta el fin, para entender el flujo y confirmar su conocimiento del proceso.
7. **Pruebas de Cumplimiento (o de Controles):** Pruebas diseñadas para verificar que un control específico está operando de manera efectiva. Por ejemplo, el auditor toma una muestra de 50 solicitudes de acceso a un sistema crítico y verifica que todas tengan la firma de autorización del jefe correspondiente.
8. **Pruebas Sustantivas:** Pruebas sobre los datos mismos para detectar errores o irregularidades, especialmente si los controles son débiles. Por ejemplo, el auditor utiliza un software de análisis (CAATT) para identificar todos los pagos a proveedores que superen un millón de córdobas y no tengan una orden de compra asociada.

9. Uso de Herramientas de Auditoría (CAATTs): En la auditoría de TI, el uso de software especializado es fundamental. Las Técnicas de Auditoría Asistidas por Computadora (CAATT) incluyen:
10. Software de Análisis de Datos: Como ACL o IDEA, que permiten analizar grandes volúmenes de datos de bases de datos para identificar patrones, duplicados, excepciones, etc.
11. Scripts SQL: Consultas personalizadas a bases de datos para extraer información específica.
12. Herramientas de Escaneo de Vulnerabilidades: Como Nessus u OpenVAS, para identificar debilidades en sistemas y redes.
13. Herramientas de Análisis de Logs: Para revisar eventos de seguridad.
14. Documentación de la Evidencia (Papeles de Trabajo): Cada procedimiento realizado, cada documento revisado, cada entrevista, debe quedar registrado en los papeles de trabajo. Estos son el soporte físico o electrónico que respalda todas las conclusiones del auditor. Deben ser claros, completos, referenciados y organizados para que otro auditor pueda revisarlos y entender el trabajo realizado.

Ejemplo en Nicaragua:

Continuando con el ejemplo de LA COLMENA, en la fase de trabajo de campo, el auditor:

Entrevista al encargado de bodega.

Observa cómo se realiza un conteo cíclico de productos.

Realiza una prueba de cumplimiento: toma los registros de los últimos 10 conteos cíclicos y verifica que todos estén firmados por el supervisor.

Realiza una prueba sustantiva utilizando CAATT: extrae del sistema ERP el listado de inventario valorado y lo compara con el reporte de conteos físicos del último mes para identificar diferencias significativas.

Documenta todo en sus papeles de trabajo, incluyendo las notas de la entrevista, las fotografías de la observación, las capturas de pantalla de los análisis de datos y las conclusiones preliminares.

Fase 3: Desarrollo de Hallazgos y Conclusiones

Una vez recolectada la evidencia, el auditor debe analizarla, estructurarla y formular sus hallazgos y conclusiones. Un hallazgo de auditoría bien definido es la base para un buen informe.

1. Elementos de un Hallazgo de Auditoría (Atributos): Un hallazgo debe responder a cinco preguntas fundamentales, conocidas como los atributos del hallazgo:
2. Condición (Lo que es): Describe la situación real encontrada por el auditor. Es el hecho concreto. Ejemplo: "Se identificaron 15 cuentas de usuario de exempleados que aún se encuentran activas en el sistema de facturación".
3. Criterio (Lo que debe ser): Es la norma, política, estándar o procedimiento con el que se compara la condición. Es la "ley" que se está incumpliendo. Ejemplo: "La política de seguridad de la empresa, en su sección 5.2, establece que 'las cuentas de usuario deben ser desactivadas dentro de las 24 horas siguientes a la fecha de desvinculación del empleado'."
4. Causa (Por qué ocurre): Es la razón fundamental por la que se produce la condición. No es la excusa, es la raíz del problema. Ejemplo: "La causa es la falta de un procedimiento automatizado de sincronización entre el sistema de Recursos Humanos y el sistema de facturación, y la ausencia de revisiones periódicas de las cuentas de usuario por parte del área de TI."
5. Efecto (Qué consecuencia tiene): Es el impacto real o potencial de la condición en la organización. Debe expresarse en términos de negocio. Ejemplo: "Esto expone a la empresa al riesgo de que un exempleado pueda acceder al sistema de facturación, con la consecuente posibilidad de manipular información confidencial de clientes, realizar facturaciones fraudulentas o cometer actos de sabotaje, afectando la confidencialidad e integridad de la información."
6. Recomendación (Qué hacer): Es la sugerencia del auditor para corregir la causa y, por ende, la condición, y prevenir que vuelva a ocurrir. Ejemplo: "Implementar un proceso automatizado que desactive las cuentas de usuario

en el sistema de facturación al momento de ser dadas de baja en el sistema de Recursos Humanos. Adicionalmente, realizar una revisión trimestral de todas las cuentas de usuario para depurar aquellas que ya no sean necesarias."

7. Conclusiones: Las conclusiones son las opiniones profesionales del auditor basadas en la totalidad de la evidencia y los hallazgos. Responden a los objetivos de la auditoría. Por ejemplo: "En opinión del auditor, los controles de acceso al sistema de facturación son parcialmente efectivos. Si bien la autenticación de usuarios es robusta, la gestión de bajas de usuarios es deficiente, lo que representa un riesgo moderado para la organización."

Fase 4: Comunicación de Resultados (El Informe)

El producto final de la auditoría es el informe. Debe ser claro, conciso, objetivo y útil para la toma de decisiones. Se redacta en un lenguaje que la gerencia (que no necesariamente es técnica) pueda entender.

Estructura Típica de un Informe de Auditoría de TI:

1. Título e Identificación: A quién va dirigido, auditores, fecha, período auditado.
2. Introducción: Contexto de la auditoría, autorización (carta de encargo).
3. Objetivos y Alcance: Descripción clara de qué se auditó y con qué propósito.
4. Limitaciones al Alcance (si las hubo): Cualquier restricción que impidió al auditor realizar su trabajo según lo planeado.
5. Resumen Ejecutivo (para la alta dirección): Síntesis de los hallazgos más importantes, las conclusiones generales y las recomendaciones clave. Debe ser de máximo una o dos páginas.
6. Cuerpo del Informe (Detalle de Hallazgos): Para cada hallazgo significativo, se presenta la condición, criterio, causa, efecto y recomendación de manera estructurada.

7. Opinión o Conclusiones Generales: La valoración global del auditor sobre el área auditada.
8. Anexos: Pueden incluir detalles de la muestra, listado de personas entrevistadas, glosario de términos técnicos, etc.
9. Antes de emitir el informe final, el auditor debe realizar una reunión de cierre (o de lectura de borrador) con los auditados. El propósito es:
10. Validar los hechos (condición) para asegurarse de que no hay errores.
11. Discutir las causas y efectos.
12. Acordar las recomendaciones y los plazos para su implementación.

Fase 5: Seguimiento

La auditoría no termina con la entrega del informe. La fase de seguimiento es crucial para cerrar el ciclo y asegurar que la auditoría genera valor.

Actividades Clave:

1. Obtención del Plan de Acción: El auditado debe presentar un plan formal con las acciones correctivas que implementará, los responsables y las fechas de cumplimiento.
2. Monitoreo del Progreso: El auditor realiza un seguimiento periódico (a través de reportes o reuniones) para verificar que el plan de acción avanza según lo previsto.
3. Verificación de la Implementación: En una auditoría posterior, o mediante una revisión específica, el auditor verifica que las acciones correctivas se hayan implementado y que sean efectivas para resolver el problema de raíz. Si no es así, el hallazgo puede reiterarse en el próximo informe.

Autoevaluación

Responde las siguientes preguntas para verificar tu comprensión sobre el proceso metodológico de la auditoría de TI.

Pregunta 1:

¿Cuál es la fase más importante del proceso de auditoría, donde se define el alcance, los objetivos y el programa de trabajo?

- a) Trabajo de campo
- b) Comunicación de resultados
- c) Planificación
- d) Seguimiento

Pregunta 2:

Un auditor, para verificar si el control de "aprobación de facturas de proveedores" está operando, selecciona una muestra de 30 facturas y revisa si todas tienen la firma del jefe de compras. ¿Qué tipo de prueba está realizando?

- a) Prueba sustantiva
- b) Prueba de recorrido (walkthrough)
- c) Prueba de cumplimiento
- d) Prueba de análisis de datos

Pregunta 3:

En la estructura de un hallazgo de auditoría, la frase "La política interna establece que las claves deben cambiarse cada 60 días" corresponde al atributo de:

- a) Condición
- b) Criterio
- c) Causa
- d) Efecto

Pregunta 4:

¿Cuál es el propósito principal de la reunión de cierre (o de lectura de borrador) con el auditado?

- a) Entregar el informe final y cobrar los honorarios.
- b) Validar los hallazgos, discutir las causas y acordar las recomendaciones.
- c) Iniciar formalmente la auditoría.
- d) Realizar las pruebas de auditoría.

Pregunta 5 (Caso práctico):

Un auditor de la Dirección General de Ingresos (DGI) ha finalizado el trabajo de campo de una auditoría al sistema de facturación electrónica. Ha encontrado varias inconsistencias y las ha documentado en sus papeles de trabajo. Su siguiente paso, antes de redactar el informe final, debe ser:

- a) Enviar el informe final al Director de la DGI.
- b) Archivar los papeles de trabajo y dar por terminada la auditoría.
- c) Programar una reunión de cierre con los responsables del sistema de facturación para discutir los hallazgos preliminares.
- d) Iniciar la fase de seguimiento para verificar las correcciones.

Evaluación Integral

Esta evaluación tiene como propósito verificar la comprensión y aplicación de los conceptos fundamentales abordados en la Unidad II. A lo largo de tres temas, hemos explorado:

1. Antecedentes y Conceptos generales (metodología, enfoque, técnica, procedimiento).
2. Metodologías de Evaluación de los recursos de TI (COBIT, ITIL, ISO 27001, COSO, Riesgos).
3. Proceso Metodológico de Auditoría de TI (Planificación, Trabajo de Campo, Desarrollo de Hallazgos, Comunicación, Seguimiento).

La evaluación consta de cinco secciones que combinan preguntas teóricas, casos prácticos contextualizados en Nicaragua, análisis de situaciones y un ensayo. El objetivo es demostrar la capacidad para aplicar estos marcos metodológicos en contextos profesionales concretos.

Sección 1: Preguntas de Selección Múltiple (20 puntos)

Instrucciones: Selecciona la opción que mejor responda cada pregunta. Cada respuesta correcta vale 2 puntos.

1.1. ¿Cuál es la principal diferencia entre una técnica y un procedimiento de auditoría?

- a) La técnica es el marco general; el procedimiento es la perspectiva.
- b) La técnica es el método específico; el procedimiento es la secuencia de pasos para aplicar ese método.
- c) No hay diferencia, son sinónimos.
- d) El procedimiento es el "qué" y la técnica es el "cómo".

1.2. Un auditor de TI que necesita evaluar la madurez de los procesos de gestión de TI y su alineamiento con el negocio, debería utilizar como marco de referencia principal:

- a) ITIL
- b) ISO 27001
- c) COBIT
- d) MAGERIT

1.3. En la fase de planificación, la definición del "programa de trabajo" consiste en:

- a) Establecer los límites de la auditoría.
- b) Elaborar un listado detallado de los procedimientos a realizar, con tiempos y responsables.
- c) Enviar la carta de encargo al auditado.
- d) Realizar una evaluación preliminar de riesgos.

1.4. La "condición" en un hallazgo de auditoría se refiere a:

- a) La norma o política que se está incumpliendo.
- b) La situación real encontrada por el auditor.
- c) El impacto potencial del problema en el negocio.
- d) La recomendación para corregir el problema.

1.5. ¿Cuál de las siguientes es una técnica de auditoría asistida por computadora (CAATT)?

- a) Realizar una entrevista al jefe de TI.
- b) Revisar la política de seguridad de la información.
- c) Utilizar el software ACL para identificar pagos duplicados en una base de datos.
- d) Observar cómo un operador realiza un backup.

1.6. La fase del proceso de auditoría donde se verifica que las recomendaciones hayan sido implementadas por la gerencia se llama:

- a) Trabajo de campo
- b) Comunicación de resultados
- c) Planificación
- d) Seguimiento

1.7. Si un auditor se enfoca en evaluar la calidad del servicio de TI, midiendo si se cumplen los acuerdos de nivel de servicio (SLA), está aplicando criterios del marco:

- a) COBIT
- b) ITIL
- c) COSO
- d) NIST

1.8. ¿Cuál de los siguientes es un ejemplo de un control de aplicación que un auditor podría probar en la fase de trabajo de campo?

- a) Verificar que los cambios al sistema sean aprobados por un comité.
- b) Revisar que el sistema valide que una factura no pueda tener un monto negativo.
- c) Confirmar que los servidores tengan parches de seguridad actualizados.
- d) Evaluar el plan de continuidad del negocio.

1.9. El enfoque de auditoría que centra los esfuerzos en las áreas, sistemas o procesos de mayor riesgo se denomina:

- a) Enfoque de controles.
- b) Enfoque sistémico.
- c) Enfoque basado en riesgos.
- d) Enfoque de cumplimiento.

1.10. El propósito principal de la reunión de cierre (o de lectura de borrador) es:

- a) Iniciar formalmente los procedimientos de auditoría.
- b) Entregar el informe final y cobrar los honorarios.
- c) Validar los hallazgos con el auditado y acordar las recomendaciones.

d) Realizar las pruebas de cumplimiento.

Sección 2: Términos Pareados (15 puntos)

Instrucciones: Relaciona cada concepto de la columna izquierda con su descripción correcta en la columna derecha. Escribe la letra correspondiente en el paréntesis. Cada relación correcta vale 1.5 puntos.

CONCEPTO	DESCRIPCIÓN
2.1. METODOLOGÍA ()	A. Secuencia detallada de pasos para aplicar una técnica.
2.2. ENFOQUE ()	B. Herramienta informática para análisis de datos en auditoría (ej. ACL).
2.3. TÉCNICA ()	C. Método específico para obtener evidencia, como la entrevista o el análisis de datos.
2.4. PROCEDIMIENTO ()	D. Atributo del hallazgo que responde a "¿qué consecuencia tiene?".
2.5. CAATT ()	E. Fase donde se ejecuta el programa de trabajo.
2.6. CONDICIÓN ()	F. La perspectiva o estrategia que se adopta para abordar una auditoría.
2.7. EFECTO ()	G. Atributo del hallazgo que responde a "¿qué es lo que está mal?".
2.8. TRABAJO DE CAMPO ()	H. Fase donde se define el alcance y el programa de trabajo.
2.9. PLANIFICACIÓN ()	I. El marco general y sistemático que guía todo el proceso de auditoría.
2.10. SEGUIMIENTO ()	J. Fase donde se verifica la implementación de las recomendaciones.

Sección 3: Preguntas de Desarrollo Corto (20 puntos)

Instrucciones: Responde de manera clara y concisa cada pregunta. Cada respuesta correcta y bien fundamentada vale 4 puntos.

3.1. Explica brevemente la diferencia entre una prueba de cumplimiento y una prueba sustantiva. Proporciona un ejemplo de cada una en el contexto de una auditoría al sistema de cuentas por pagar de una empresa.

3.2. Describe los cinco atributos de un hallazgo de auditoría (Condición, Criterio, Causa, Efecto, Recomendación) y explica brevemente qué pregunta responde cada uno.

3.3. Menciona y explica brevemente dos de las cinco fases del proceso metodológico de auditoría de TI, indicando la actividad principal que se realiza en cada una.

3.4. ¿Por qué es importante que un auditor de TI en Nicaragua conozca y utilice marcos como COBIT, ITIL e ISO 27001 en su trabajo, incluso si la organización no está certificada en ellos?

3.5. Un auditor está planificando una auditoría al sistema de banca en línea de un banco nicaragüense. ¿Qué tipo de enfoque debería adoptar y por qué? (Explica tu respuesta basándote en el concepto de enfoque).

Sección 4: Casos Prácticos Contextualizados en Nicaragua (30 puntos)

Instrucciones: Analiza cada caso y responde las preguntas planteadas. Demuestra tu capacidad para aplicar los conceptos de la unidad a situaciones reales. Cada caso vale 10 puntos.

Caso 1: La Fintech "PagoYa" Nicaragua

"PagoYa" es una startup nicaragüense que ofrece una aplicación móvil para pagos y transferencias entre personas. La empresa está en rápido crecimiento y acaba de ser adquirida por un grupo financiero internacional. Como parte del proceso de adquisición, la matriz ha solicitado una auditoría de TI exhaustiva para evaluar los controles y la gestión de la tecnología. Tú eres el auditor líder de la firma contratada para realizar esta auditoría.

Preguntas:

- a) El equipo de auditoría debe decidir el enfoque de la auditoría. Dado que los recursos son limitados y el tiempo es corto, ¿qué enfoque recomendarías y por qué? (2 puntos)
- b) Necesitas evaluar la gestión de la seguridad de la información de "PagoYa". Menciona dos marcos de referencia (de los estudiados) que podrías utilizar para guiar tu evaluación y explica brevemente cómo usarías cada uno. (3 puntos)
- c) Al revisar el proceso de desarrollo de la aplicación, encuentras que los programadores pueden hacer cambios directamente en el código de producción sin ninguna revisión ni aprobación previa. ¿Qué tipo de control general de TI es deficiente? Redacta el hallazgo siguiendo los atributos de Condición, Criterio (puedes inventar un criterio razonable) y Efecto. (5 puntos)

Caso 2: La Alcaldía de "Villa Hermosa"

La Contraloría General de la República (CGR) ha incluido en su plan anual una auditoría al sistema de gestión tributaria de la Alcaldía de "Villa Hermosa" (una ciudad intermedia de Nicaragua). El objetivo es evaluar la confiabilidad de los ingresos por impuesto de bienes inmuebles (IBI). Tú formas parte del equipo de auditores de la CGR.

Preguntas:

- a) En la fase de planificación, ¿qué información necesitas recopilar para conocer el negocio y el entorno a auditar? Menciona al menos tres aspectos clave. (3 puntos)
- b) Ya en el trabajo de campo, decides aplicar una prueba sustantiva utilizando CAATT. Tienes acceso a la base de datos del IBI, que contiene el padrón de contribuyentes y los registros de pago. Describe una prueba concreta que podrías realizar con una herramienta de análisis de datos para verificar la integridad de los ingresos. (3 puntos)
- c) Tu prueba revela que 50 propiedades de gran tamaño (centros comerciales, hoteles) no aparecen en el padrón de contribuyentes. Al indagar, te dicen que "son propiedades de personas influyentes y siempre ha sido así". Siguiendo el escepticismo profesional, ¿cómo documentarías este hallazgo? Define la Causa y la Recomendación. (4 puntos)

Caso 3: El Hospital Privado "La Esperanza"

El Hospital Privado "La Esperanza" en Managua maneja historiales clínicos electrónicos de sus pacientes (datos de salud, considerados datos sensibles por la Ley 1042). Recientemente, un paciente se quejó porque recibió publicidad de una clínica de maternidad, y él nunca ha dado su consentimiento para ese tipo de comunicaciones. La dirección del hospital, temiendo una denuncia formal ante la ARESEP, te contrata como consultor independiente para que realices una auditoría enfocada en este tema.

Preguntas:

- a) ¿Qué tipo de auditoría de TI (según su enfoque) necesitas realizar principalmente? (1 punto)

b) Para evaluar si el hospital protege adecuadamente los datos personales, ¿qué norma internacional (de las estudiadas) utilizarías como principal checklist de controles? ¿Por qué? (2 puntos)

c) En tu revisión, encuentras que cualquier empleado con acceso al sistema puede ver el historial completo de cualquier paciente, sin que quede registro (log) de quién lo consultó. Redacta el hallazgo completo (Condición, Criterio - mencionando la Ley 1042 -, Causa, Efecto y Recomendación). (5 puntos)

d) Según el proceso metodológico, ¿cuál debería ser tu siguiente acción después de entregar el informe con esta recomendación? (2 puntos)

Sección 5: Ensayo Corto (15 puntos)

Instrucciones: Redacta un ensayo de una página (aproximadamente 300-400 palabras) que responda a la siguiente pregunta. Se evaluará la claridad de la idea, la estructura del texto, la fundamentación en los conceptos de la unidad y la capacidad de análisis crítico.

Tema del ensayo:

"Imagina que eres el líder del equipo de auditoría de TI en una empresa nicaragüense de tamaño mediano (por ejemplo, una distribuidora o una cooperativa) que nunca ha sido auditada en el área de TI. El gerente general te pregunta: '¿Por qué no podemos simplemente revisar los sistemas nosotros mismos? ¿Para qué necesitamos una metodología tan complicada con fases, atributos y marcos como COBIT o ITIL?'."

Redacta tu respuesta en forma de ensayo, explicándole al gerente general (en un lenguaje que no sea demasiado técnico) la importancia de seguir una metodología estructurada. Tu ensayo debe:

- Definir brevemente qué es una metodología de auditoría.
- Explicar al menos tres beneficios clave de usar una metodología (ej. rigor, eficiencia, objetividad, defendibilidad, alineación con estándares).
- Mencionar cómo marcos como COBIT o ISO 27001 ayudan a tener un "checklist" de lo que se debe revisar, evitando que la revisión sea incompleta o subjetiva.
- Usar un ejemplo sencillo y concreto (puede ser de los casos vistos) para ilustrar cómo una revisión "informal" podría pasar por alto un riesgo grave que una auditoría metodológica sí detectaría.
- Concluir con una reflexión sobre el valor que una auditoría metodológica aporta a la organización para la toma de decisiones.

Criterios de Evaluación

SECCIÓN	PUNTAJE	CRITERIOS DE EVALUACIÓN
SECCIÓN 1: SELECCIÓN MÚLTIPLE	20 puntos	Respuestas correctas según la clave.
SECCIÓN 2: TÉRMINOS PAREADOS	15 puntos	Correspondencia correcta entre conceptos y descripciones.
SECCIÓN 3: DESARROLLO CORTO	20 puntos	Claridad, precisión y fundamentación en los conceptos de la unidad (4 puntos cada pregunta).
SECCIÓN 4: CASOS PRÁCTICOS	30 puntos	Capacidad para aplicar los conceptos a situaciones concretas, justificación de las respuestas, identificación correcta de problemas y soluciones (10 puntos cada caso).
SECCIÓN 5: ENSAYO CORTO	15 puntos	Claridad de la tesis, estructura del ensayo, solidez de los argumentos (fundamentados en la unidad), ejemplos contextualizados, y conclusión reflexiva.
TOTAL	100 puntos	

Bibliografía y Webgrafía

- Contraloría General de la República de Nicaragua. (2023). Normas de Auditoría Gubernamental de Nicaragua (NAGUN) - Actualización 2023.
- Gómez Vieites, Á. (2020). Auditoría de seguridad informática (2ª ed.). Ra-Ma.
- Hernández Hernández, E. (2018). Auditoría en tecnologías de información: Enfoque metodológico y práctico (3ª ed.). Alfaomega.
- ISACA. (2019). COBIT 2019: Marco de referencia para el gobierno y la gestión de la información y la tecnología.
- ISACA. (2021). CISA Review Manual (27th ed.).
- ISO/IEC. (2022). ISO/IEC 27001:2022 - Tecnología de la información - Técnicas de seguridad - Sistemas de Gestión de Seguridad de la Información (SGSI) - Requisitos.
- ITIL. (2019). ITIL Foundation: ITIL 4 Edition. AXELOS.
- Muñoz Razo, C. (2015). Auditoría en tecnologías de información (2ª ed.). Pearson Educación.
- NIST. (2012). NIST Special Publication 800-30, Revision 1: Guide for Conducting Risk Assessments.
- Piattini, M. G., Del Peso, E., & Peso, M. del. (2020). Auditoría de tecnologías y sistemas de información (3ª ed.). Ra-Ma.
- Superintendencia de Bancos y de Otras Instituciones Financieras (SIBOIF). (2020). Norma sobre Gestión de Riesgos de Tecnologías de Información (Resolución CD-SIBOIF-1234-2020). (Normativa de ejemplo).

- **Alcance de la Auditoría:** Límites definidos de una auditoría, especificando qué procesos, sistemas, ubicaciones, períodos de tiempo y actividades serán objeto de revisión.
- **Atributos del Hallazgo:** Los elementos que debe contener un hallazgo de auditoría para ser completo y útil: Condición, Criterio, Causa, Efecto y Recomendación.
- **CAATT (Computer Assisted Audit Techniques):** Técnicas de Auditoría Asistidas por Computadora. Herramientas y programas informáticos que utiliza el auditor para analizar datos, probar controles y extraer evidencia de los sistemas (ej. ACL, IDEA, scripts SQL).
- **Causa (del hallazgo):** La razón fundamental o raíz que origina la condición encontrada. Responde a la pregunta "¿por qué ocurrió?".
- **Condición (del hallazgo):** La situación real o factual encontrada por el auditor durante su revisión. Es el "qué es" de la realidad.
- **Criterio (del hallazgo):** La norma, estándar, política, ley o procedimiento contra el cual el auditor compara la condición. Es el "qué debe ser".
- **Efecto (del hallazgo):** El impacto real o potencial (riesgo) que la condición tiene sobre los objetivos de la organización. Responde a la pregunta "¿y qué?" o "¿qué consecuencias tiene?".
- **Enfoque de Auditoría:** La estrategia o perspectiva que se adopta para realizar una auditoría, determinando dónde se pondrá el énfasis (ej. enfoque basado en riesgos, enfoque de controles).
- **Hallazgo de Auditoría:** Resultado de la comparación entre la condición encontrada y el criterio aplicable. Es una desviación, debilidad, oportunidad de mejora o irregularidad identificada.
- **Metodología de Auditoría:** El marco general y sistemático de principios, métodos y reglas que guían todo el proceso de auditoría, desde la planificación hasta el seguimiento.

- Papeles de Trabajo: El conjunto de documentos, registros y evidencias que el auditor prepara y obtiene durante el curso de la auditoría, y que sirven como soporte a sus hallazgos, conclusiones e informe.
- Planificación de la Auditoría: Primera fase del proceso de auditoría, donde se definen los objetivos, el alcance, el enfoque, el programa de trabajo y los recursos necesarios.
- Procedimiento de Auditoría: Conjunto detallado y secuencial de pasos o instrucciones para realizar una prueba o técnica de auditoría específica.
- Programa de Trabajo: Documento detallado que lista los procedimientos de auditoría a realizar, su secuencia, el responsable y el tiempo asignado. Es la "hoja de ruta" de la auditoría.
- Prueba de Cumplimiento (o de Controles): Procedimiento de auditoría diseñado para obtener evidencia sobre la efectividad operativa de un control interno (si existe, si se aplica y si funciona).
- Prueba de Recorrido (Walkthrough): Técnica de auditoría que consiste en seguir el rastro de una o pocas transacciones a través del proceso o sistema, desde su origen hasta su destino final, para confirmar el entendimiento del auditor sobre el flujo y los controles.
- Prueba Sustantiva: Procedimiento de auditoría diseñado para obtener evidencia directa sobre la integridad, exactitud y validez de los datos o transacciones.
- Recomendación (del hallazgo): La sugerencia del auditor para corregir la causa de la condición encontrada y prevenir su recurrencia.
- Reunión de Cierre: Reunión celebrada al finalizar el trabajo de campo, donde el auditor presenta los hallazgos preliminares al auditado para validar los hechos, discutir las causas y efectos, y acordar las recomendaciones y plazos de acción.
- Seguimiento (de Auditoría): Quinta y última fase del proceso, donde el auditor verifica que las recomendaciones han sido implementadas por la gerencia y que las acciones correctivas han sido efectivas.

- Técnica de Auditoría: Método o herramienta específica utilizada por el auditor para obtener evidencia o realizar una revisión puntual (ej. entrevista, observación, análisis de datos, cuestionario).
- Trabajo de Campo (Ejecución): Segunda fase del proceso de auditoría, donde se ejecuta el programa de trabajo y se recolecta la evidencia mediante la aplicación de diversas técnicas.